

doc_id: POL-07

title: Information Security

version: 1.0

effective_date: 2026-01-01

category: Security

Information Security

This policy sets the minimum security requirements that protect Acme Corp's people, customers and information. It applies to all employees, contractors and anyone else with access to Acme Corp systems or information, wherever they work.

Policy owner: IT Security team.

Why Security Matters

Most security incidents begin with a simple mistake: a weak or reused password, a convincing phishing email, or a lost laptop. Following this policy keeps those mistakes from becoming breaches. Breaking this policy may lead to disciplinary action under the Code of Conduct and Anti-Harassment policy (POL-10).

Passwords

All passwords for Acme Corp accounts must meet these rules:

- A minimum length of 14 characters.
- No reuse of a password across different accounts, and no reuse of any of your last 10 Acme Corp passwords.
- No passwords based on easily guessed personal information, such as names, birthdays or the word "Acme".

Long passphrases made of four or more unrelated words are encouraged.

Passwords do not expire on a fixed schedule. You must change a password immediately if you suspect it has been seen or compromised, or when the IT Security team asks you to.

Password Manager

Every employee must store work passwords in the company password manager, which is installed on every company laptop. Never write passwords down, store them in documents or spreadsheets, or share them with anyone, including IT staff. IT staff will never ask for your password.

Multi-Factor Authentication (MFA)

Multi-factor authentication is required for every Acme Corp system that supports it, including email, chat, PeopleHub, the expense system, code repositories and the VPN.

The approved second factors are, in order of preference: a hardware security key issued by IT, or the company authenticator app. SMS codes are not allowed except as a temporary fallback of up to 7 days while a replacement key is issued.

Never approve an MFA prompt you did not start. Unexpected MFA prompts must be reported as a security incident.

Devices

Company Laptops

- Company laptops are encrypted with full-disk encryption, which must never be disabled.
- Screens must lock automatically after 5 minutes of inactivity. Lock your screen manually whenever you leave your device.
- Operating system and application security updates must be installed within 7 days of release. Laptops that are more than 14 days behind are blocked from the VPN until updated.
- Endpoint protection software must remain installed and running.

Lost or Stolen Devices

Report a lost or stolen company device, or a personal phone with company email on it, as a security incident within 1 hour of noticing the loss. IT will remotely lock and wipe the device.

Personal Devices

Rules about using personal devices for work are in the Acceptable Use of IT policy (POL-08).

Network Access

Use the company VPN whenever you access company systems from any network other than an Acme Corp office network, including home, hotel and public Wi-Fi. The requirements for remote working are summarised in the Remote and Hybrid Work policy (POL-05).

Never connect unapproved network equipment, such as personal wireless routers, to an Acme Corp office network.

Access Control

Access to systems and data is granted on a least-privilege basis: you receive only the access your role needs. Access requests are made through the IT Service Desk and approved by the system owner.

Managers must review their team's access to sensitive systems every 6 months. When an employee changes role, access that is no longer needed is removed within 5 working days. When an employee leaves, all access is removed on their last working day.

Administrator rights on laptops are granted only for specific technical roles and must be reviewed every 6 months.

Email and Phishing

Be suspicious of unexpected messages that create urgency, ask for credentials or payments, or contain unexpected attachments or links. Use the "Report phishing" button in your email client to report suspicious emails. Do not forward them to colleagues.

All employees must complete security awareness training within 30 days of joining and then once every year. The IT Security team runs simulated phishing exercises; employees who click a simulated phishing link are assigned a short refresher module.

Incident Reporting

A security incident is any event that may put the confidentiality, integrity or availability of Acme Corp information or systems at risk. Examples include a suspected phishing compromise, a lost device, malware, sending Confidential data to the wrong recipient, or an unexpected MFA prompt.

Report every suspected security incident to the IT Security team within 1 hour of discovering it, by email to security@acme.example or by calling the 24-hour security hotline listed on the intranet. Report it even if you are unsure whether it is really an incident; there is no penalty for reporting in good faith.

Do not try to investigate the incident yourself, and do not delete evidence such as suspicious emails.

Incident Response

The IT Security team classifies each incident by severity, from Sev-1 (critical) to Sev-4 (low). Sev-1 incidents are escalated to the Chief Information Security Officer immediately. If an incident involves personal data, the IT Security team informs the Data Protection Officer, who handles any regulatory notification under the Data Privacy and Retention policy (POL-09).

Handling Information

Information must be handled according to its classification level, as defined in the Data Privacy and Retention policy (POL-09). In summary, Confidential and Restricted information must only be stored in approved company systems, must be encrypted when sent outside Acme Corp, and must never be pasted into unapproved external tools, including public AI chatbots.

Clear Desk and Screen

Leave no Confidential or Restricted information on desks, printers or whiteboards at the end of the day. Use the secure shredding bins for printed documents. Position screens so that sensitive information cannot easily be read by others in public places.

Software Development Security

Engineering teams must use code review for every change, scan dependencies for known vulnerabilities, and never commit secrets such as API keys to source code. Secrets are stored in the company secrets manager.

Third Parties

Suppliers who will access Acme Corp systems or Confidential information must complete a security assessment by the IT Security team before a contract is signed.

Exceptions

Exceptions to this policy must be requested through the IT Service Desk, approved in writing by the IT Security team, and reviewed at least every 12 months.

Document Control

Version 1.0, effective 1 January 2026, owner IT Security team. First release.